



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management



إدارة الجودة والتطوير
 Quality & Development Management

شركة دايموند لوساطة التأمين

إجراءات قسم الأمن السيبراني

يناير 2025



الاسم المسجل: شركة الوثيقة الماسية لوساطة التأمين

المركز الرئيسي: طريق النمامة، الربيع، الرياض

مسؤول المستند: مشرف تقنية المعلومات

ادارة المستند

مراقبة المستند :

أعدها	الوظيفة	التاريخ	التوقيع
نوف الرعوي	مسؤول الجودة والتطوير	29/01/2025	
راجعها	الوظيفة	التاريخ	التوقيع
شادن العتيبي	إدارة الجودة والتطوير	02/02/2025	
اعتمدها مبدئياً	الوظيفة	التاريخ	التوقيع
جيثن فيركي	مشرف تقنية المعلومات	13/03/2025	
اعتمدها نهائياً	الوظيفة	التاريخ	التوقيع
بدر الشايع	العضو المنتدب	13/03/2025	

تاريخ المراجعة:

رقم الاصدار	تاريخ التنفيذ	موقع التغيير	وصف التغيير

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



DO NOT COPY

جدول المحتويات

إدارة المستند

إدارة الجودة والتطوير

إدارة الجودة والتطوير

القسم الأول- إجراءات التشغيل القياسية

1. مقدمة

- 1.1 الغرض
- 1.2 الفئات المستهدفة
- 1.3 التعريفات
- 1.4 مراقبة المستند
- 1.5 الملكية والمراجعة
- 1.6 تغييرات على إجراءات التشغيل القياسية
- 1.7 تطبيقات تقنية المعلومات
- 1.8 الأنشطة الرئيسية
- 1.9 لمحة عامة عن الإدارة
- 1.10 الأدوار والمسؤوليات

1.10.1 إدارة الهوية والوصول

1.10.1.1 إنشاء الحسابات

1.10.1.2 مابعد إنشاء الحسابات

1.10.1.3 مابعد حذف الحسابات

1.10.2 اختبار الأنظمة

1.10.3 الاستجابة للحوادث

1.10.3.1 آلية الاستجابة للحوادث

1.11 تفويض الصلاحية

2. التقارير الداخلية

- 2.1 الخلفية
- 2.2 العملية

3. اللوائح السارية

4. التوظيف والتدريب

5. حفظ السجلات

5.1 السجلات الالكترونية

5.1.1 استعادة المعلومات أو نقلها من جهاز إلى آخر

5.1.2 خطة الطوارئ لتجنب فشل عملية النسخ الاحتياطي

6 المراجع

القسم الأول- إجراءات التشغيل القياسية

1 مقدمة:

تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من إجراءات التشغيل القياسية الخاصة بها هو تمكين المؤسسة من تحقيق أهدافها الاستراتيجية من خلال تطبيقات أمنية قوية تمكن الشركة من حماية بياناتها وأصولها الرقمية لضمان استمرارية أعمالها والحفاظ على سمعتها تحدد إجراءات التشغيل القياسية الأدوار والمسؤوليات والعمليات الخاصة بالأفراد المشاركين في أنشطة الدعم السيبراني ووضع الضوابط الرئيسية ضمن الأنشطة المنفذة من قسم الأمن السيبراني لتعزيز الهيكل العام للشركة.

1.1 الغرض:

الهدف من إجراءات التشغيل القياسية هي:

- حماية الأصول المعلوماتية التي تشمل حماية البيانات والأنظمة والتطبيقات من التهديدات السيبرانية.
- ضمان استمرارية الأعمال من خلال حماية أنظمة الكمبيوتر والشبكات من السرقة أو التلف أو الوصول غير المصرح به إلى البيانات التي تحتفظ بها.
- الحفاظ على سمعة الشركة فحماية البيانات يحافظ على سرية معلومات العملاء الذي بدوره يزيد ثقة العميل اتجاه الشركة.

1.2 الفئات المستهدفة:

فيما يلي الفئات الموجه إليها هذا المستند:

- قسم الأمن السيبراني.
- الموظفين في قسم الأمن السيبراني.

1.3 التعريفات:

فيما يلي بعض الإختصارات والتعريفات التي تتعلق بإجراءات:

1.3.1 مصطلحات سيبرانية:

- البرامج الضارة **Malware**: برامج خبيثة مصممة لإتلاف أو تعطيل أنظمة الكمبيوتر. الأمثلة: الفيروسات والديدان وبرامج الفدية وبرامج التجسس.
- هجوم إلكتروني **Cyberattack**: محاولة لاستغلال نقاط الضعف في نظام أو شبكة للوصول غير المصرح به إلى البيانات أو تعطيل الخدمات.
- التصيد الاحتيالي **Phishing**: نوع من الهجمات الإلكترونية التي تحاول خداع المستخدمين للكشف عن معلومات حساسة، مثل كلمات المرور وأرقام بطاقات الائتمان، غالبًا عن طريق التخلي ككيان جدير بالثقة في الاتصالات الإلكترونية.
- تعطيل خدمة الرفض **DoS/DDoS**: محاولة تعطيل الخدمة أو موقع الويب عن طريق إغراقه بكمية كبيرة من حركة المرور.
- هجوم الوسيط **Man-in-the-middle attack**: فقد الاتصال بين طرفين وسرقة أو تغيير البيانات المتبادلة.
- الاختراق **Hacking**: محاولة الوصول إلى نظام أو شبكة غير مصرح به.
- الثغرات الأمنية **Vulnerabilities**: خلل في نظام الكمبيوتر أو التطبيق أو الشبكة التي يمكن أن يستغلها المهاجم للوصول غير المصرح به إلى البيانات أو الأنظمة.

1.3.2 مفاهيم سيبرانية:

- الأمن السيبراني **Cybersecurity** مجموعة تدابير وتقنيات مستخدمة للإلكترونيات والشبكات والبيانات الأمنية من البنوك السيبرانية.
- جدار الحماية **Firewall**: نظام أمان الشبكة الذي يراقب ويتحكم في حركة المرور الواردة والصادرة على الشبكة بناءً على قواعد أمان محددة مسبقًا.
- التشفير **Encryption**: تحويل البيانات إلى تنسيق غير قابل للقراءة لحمايتها من الوصول غير المصرح به.
- المصادقة **Authentication**: التحقق من هوية المستخدم أو الجهاز.
- تحديد التفويض **Authorization**: الصلاحيات التي تبرزها المستخدم أو الجهاز.
- النسخ الاحتياطي **Backup**: إنشاء نسخة من البيانات لاستعادتها في حالتها القوية أو تلفها.
- استمرارية الأعمال **Business Continuity**: خطط وإجراءات تهدف إلى ضمان استمرار العمل في حالة وقوع كارثة أو هجوم إلكتروني.
- التعافي من الكوارث **Disaster Recovery**: خطط وإجراءات تهدف إلى استعادة الأنظمة والبيانات في حالة وقوع كارثة.

1.3.3 مصطلحات ادارية:

- CEO : الرئيس التنفيذي Chief Executive Officer
- HRM : مدير الموارد البشرية Human Resources Manager
- ITM : مدير تقنية المعلومات Information Technology Manager
- TM : المدير الفني Technical Manager
- FM : المدير المالي Finance Manager
- LCM : مدير الشؤون القانونية والامتثال Legal and Compliance Manager
- OM : مدير العمليات Operation Manager
- SMD : رئيس إدارة المبيعات والتسويق Sales and Marketing Director
- QDM : مدير إدارة الجودة والتطوير Quality and Development Manager

1.3 مراقبة المستند:

- تعتبر محتويات إجراءات التشغيل القياسية هذه سرية والهدف منها فقط هو للاستخدام الداخلي في الشركة. يجب الاحتفاظ دائما بإجراءات التشغيل القياسية هذه في مكان آمن ولا يجب نسخها أو كشفها الى أطراف ثالثة.
- سوف يتم توزيع هذا المستند كاملا أو جزءا منه فقط كما هو معتمد من مدير إدارة الجودة والتطوير.
- يجب قراءة الإقسام ذات العلاقة من إجراءات التشغيل القياسية من قبل الموظفين المعنيين في الشركة بما يضمن الالتزام بإجراءات قسم الأمن السيبراني.
- سوف تظل نسخة ورقية في عهدة إدارة الجودة والتطوير.

1.4 الملكية والمراجعة:

- بينما يستخدم هذا المستند بمثابة إرشاد وتوجيه لإدارة عمليات قسم الأمن السيبراني،، يجدر ملاحظة أنه:
- يمنح العضو المنتدب الإعتماد النهائي لإجراءات التشغيل القياسية.
- يراقب مجلس الادارة حوكمة اجراءات التشغيل القياسية، ويتأكد من الطابع الرسمي على اجراءات التشغيل القياسية وتحديثها سنويا.
- تكون إدارة المستند تحت الإشراف المباشر لمشرف إدارة تقنية المعلومات.
- تضمن إدارة الجودة والتطوير وإدارة الإلتزام أن الرقابة المنفذة مناسبة وكافية طبقا لإجراءات قسم الأمن السيبراني



1.5 تغييرات على إجراءات التشغيل القياسية:

يتم إجراء تعديلات عند الضرورة على إجراء التشغيل القياسي هذا سنوياً، ومع هذا في ظل الظروف غير العادية التي تشمل الظروف الموضحة أدناه يمكن أن تحدد التعديل عند الطلب. تكون التغييرات على المستند عادة من الطبيعة التالية:

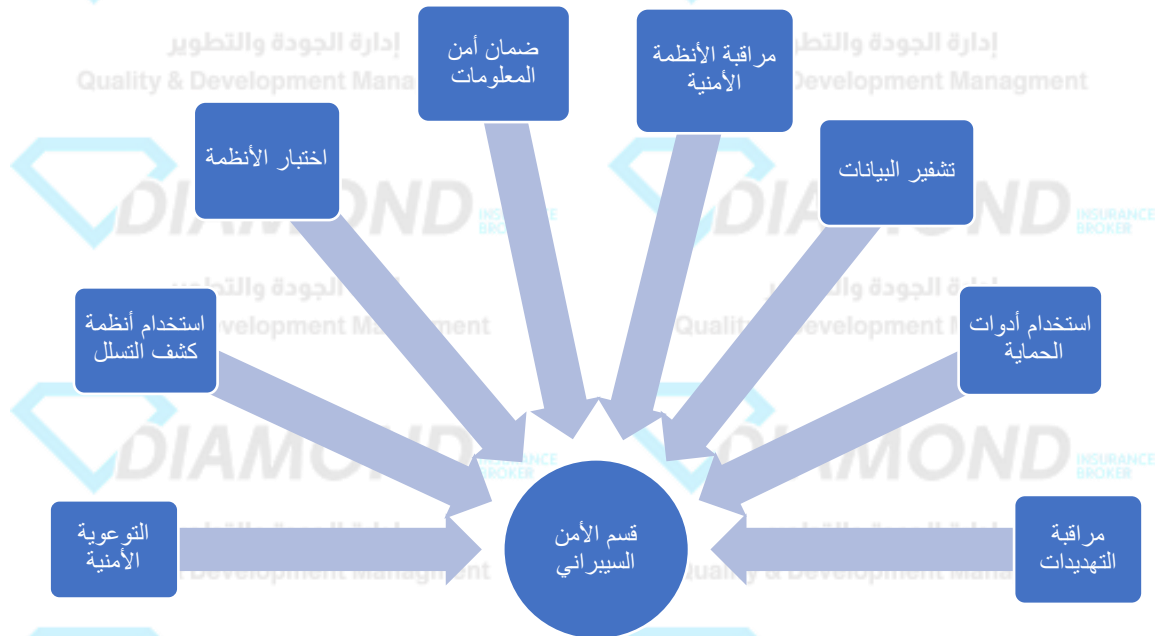
- التغييرات في القوانين واللوائح.
- التغيير في وظيفة وأنشطة الشركة.
- التغيير في إجراءات العمل.
- التغيير في الهيكل التنظيمي لشركة دايمنود.
- التغيير في الدور والواجبات والوصف الوظيفي.
- التغيير في مجموعة المخاطر التي تعمل الشركة فيها.
- أي تغيير آخر في اللوائح أو الاستراتيجية أو التشغيل.

1.6 تطبيقات تقنية المعلومات:

يتم استخدام أنظمة كشف التسلل لاكتشاف الهجمات السيبرانية كما تستخدم أدوات وتثبيتات الحماية وبرامج مكافحة الفيروسات.

1.7 الأنشطة الرئيسية:

تُعرف بدقة الخطوات والمهام ضمن إدارة الأمن السيبراني، لضمان سير العمل بسلاسة وكفاءة من خلال توفير الدعم السيبراني لجميع إدارات الشركة



1.9 ملحة عامة عن الإدارة:

يبين الشكل التالي الهيكل الحالي لقسم (الأمن السيبراني):



1.10 الأدوار والمسؤوليات :

المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تعتمد الشركة استراتيجية متكاملة للأمن السيبراني تشمل: - تقييم دوري للمخاطر الأمنية. - استخدام جدران الحماية والأنظمة المتقدمة للكشف عن التهديدات. - تطبيق تقنيات التشفير لحماية البيانات أثناء النقل والتخزين.	إدارة المخاطر
مسؤول الأمن السيبراني.	الامتثال للوائح الهيئة الوطنية للأمن السيبراني (NCA) وهيئة التأمين (AI): - تطبيق معايير AI Cybersecurity Framework لضمان الامتثال الكامل لقطاع التأمين. - تبني أفضل الممارسات العالمية مثل ISO 27001 و NIST Cybersecurity Framework. - تنفيذ برنامج تقييم مخاطر الأمن السيبراني بشكل دوري للكشف عن الثغرات وتقليل المخاطر. إدارة مخاطر الجهات الخارجية (Third-Party Risk Management - TPRM): - وضع متطلبات أمنية صارمة لمزودي الخدمات التقنية مثل أنظمة السحابة وموفري الخدمات المدارة. - إجراء تدقيق سنوي لأمن البيانات للموردين لضمان توافقهم مع سياسات الشركة	الامتثال التنظيمي وتقوية الامتثال السيبراني
مسؤول الأمن السيبراني.	- الالتزام بمتطلبات AI للإبلاغ عن الحوادث السيبرانية خلال الفترات الزمنية المحددة. - الاحتفاظ بسجلات الحوادث الإلكترونية للتدقيق والامتثال التنظيمي.	التقارير الأمنية والامتثال
مسؤول الأمن السيبراني.	- استخدام الأدوات اللازمة لإدارة كلمات المرور وتحديد الصلاحيات لمن يمكنه الوصول إلى المعلومات - تحديد مستويات الصلاحيات بناءً على الأدوار الوظيفية، لضمان عدم وصول المستخدمين غير المخولين إلى المعلومات الحساسة.	مصفوفة الصلاحيات والتحكم بالوصول



المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تلتزم الشركة بتطبيق سياسات صارمة لحماية بيانات العملاء وفقاً للأنظمة المعمول بها مثل اللائحة العامة لحماية البيانات (GDPR) وقانون حماية البيانات الشخصية السعودي (PDPL)، بما يشمل: - تحديد أليات تخزين وتأمين البيانات الحساسة. - التحكم في الوصول إلى البيانات بناءً على الأدوار والصلاحيات. - وضع إجراءات لمراقبة الاستخدام ومنع التسريبات.	حماية البيانات والخصوصية
مسؤول الأمن السيبراني.	- استخدام أنظمة الكشف عن التهديدات المستندة إلى الذكاء الاصطناعي (AI-Driven SIEM) لمراقبة الشبكة واكتشاف أي أنشطة غير طبيعية. - تنفيذ أنظمة الاستجابة الأمنية التلقائية (Security Orchestration, Automation, and Response - SOAR) لمكافحة الهجمات بشكل فوري	الحماية من التهديدات السيبرانية باستخدام الذكاء الاصطناعي (AI) والتحليلات الأمنية
مسؤول الأمن السيبراني.	- رصد التسريبات المحتملة لمعلومات الشركة أو بيانات العملاء على الإنترنت المظلم. - الاشتراك في قواعد بيانات استخبارات التهديدات السيبرانية لتحديث الدفاعات السيبرانية.	مراقبة الإنترنت العميق والدارك ويب (Dark Web Monitoring)
مسؤول الأمن السيبراني.	- تطبيق أنظمة الحماية المتقدمة لنقاط النهاية (EDR/XDR) لمنع هجمات البرمجيات الخبيثة (Malware) والهجمات المتقدمة المستمرة (APT). - تنفيذ جدران حماية من الجيل التالي (NGFW) لمراقبة الأنشطة المشبوهة ومنع التسلل.	الحماية المتقدمة لنقاط النهاية والخوادم
	- مراقبة سلوك المستخدمين على الشبكة باستخدام User Behavior Analytics (UBA). - تنفيذ سياسات صارمة للوصول إلى البيانات الحساسة ومنع نقلها خارج الشركة.	حماية الشركة من التهديدات الداخلية

المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	- استخدام أنظمة الكشف عن التهديدات المستندة إلى الذكاء الاصطناعي (AI-Driven SIEM) لمراقبة الشبكة واكتشاف أي أنشطة غير طبيعية. - تنفيذ أنظمة الاستجابة الأمنية التلقائية (Security Orchestration, Automation, and Response - SOAR) لمكافحة الهجمات بشكل فوري.	الحماية من التهديدات السيبرانية باستخدام الذكاء الاصطناعي (AI) والتحليلات الأمنية
مسؤول الأمن السيبراني.	يتم فيه مراقبة الأنظمة والشبكات بشكل مستمر للكشف عن أي نشاط مشبوه.	مراقبة الأنظمة والشبكات
مسؤول الأمن السيبراني.	تساعد في تحديد نقاط الضعف في أنظمة الشركة وتقييم المخاطر المحتملة.	تحديد المخاطر
مسؤول الأمن السيبراني.	حماية البيانات من الاختراقات والفايروسات عن طريق استخدام برامج مكافحة الفايروسات.	ضمان أمن المعلومات
مسؤول الأمن السيبراني.	- توعية الموظفين حول مخاطر الأمن السيبراني وتثقيفهم حول أفضل الممارسات الأمنية. - تنظيم اختبارات تصيد احتيالي (Phishing Simulations) شهرية لتقييم قدرة الموظفين على كشف الاحتيال. - إرسال تنبيهات دورية عن أحدث التهديدات السيبرانية عبر البريد الإلكتروني.	التوعية الأمنية
مسؤول الأمن السيبراني.	يتم نسخ وأرشفة معلومات الحواسيب حتى يتمكن استعادتها في حال فقدان البيانات الأصلية أو العبث بها.	النسخ الاحتياطي
مسؤول الأمن السيبراني.	- حفظ النسخ الاحتياطية بشكل منتظم واستعادتها عند الحاجة. - وجود خطة استجابة للهجمات الإلكترونية مثل هجمات الفدية (Ransomware). - وضع آليات واضحة لإدارة الأزمات والطوارئ.	خطة استمرارية الأعمال والتعافي من الكوارث
مسؤول الأمن السيبراني.	- محاكاة هجمات إلكترونية معقدة مثل Advanced Persistent Threats (APT). - تقييم مدى جاهزية الفريق السيبراني للتعامل مع الاختراقات الأمنية.	إجراء اختبارات هجومية دورية (Red Team vs. Blue Team Drills)



المسؤولية	النشاط	العملية الفرعية
مسؤول الأمن السيبراني.	تطوير استراتيجية المرونة السيبرانية (Cyber Resilience Strategy): - تنفيذ خطة استجابة ضد برامج الفدية (Ransomware Response Plan) لاستعادة البيانات بسرعة. - فرض تخزين بيانات غير قابلة للتغيير (Immutable Backup Storage) لحماية النسخ الاحتياطية.	تعزيز استجابة الحوادث وخطط استمرارية الأعمال
مسؤول الأمن السيبراني.	تطبيق نهج "عدم الثقة" (Zero Trust Architecture - ZTA): - تنفيذ سياسات المصادقة المستمرة لكل محاولة وصول، حتى من داخل الشبكة الداخلية. - فرض سياسات الصلاحيات الأقل امتيازًا (Least Privilege Access Control - LPAC).	التقنيات المتقدمة لتعزيز الأمن السيبراني
مسؤول الأمن السيبراني.	تأمين بيئات الحوسبة السحابية - تنفيذ سياسات أمن السحابة (Cloud Security Policies) وفق معايير CSPM - Cloud Security Posture Management. - فرض تشفير بيانات التخزين السحابي باستخدام بروتوكولات AES-256	الأمن السيبراني في البنية التحتية السحابية

1.10.1 إدارة الهوية والوصول:

ويقصد بها إدارة هويات المستخدمين والتحكم في الوصول للأنظمة والبيانات وفقاً للصلاحيات المناسبة فقط.

1.10.1.1 إنشاء الحسابات:

- 1- تحديد المستخدمين: تحديد الموظفين أو المستخدمين الذين يحتاجون إلى حسابات على النظام.
- 2- تحديد الصلاحيات: تحديد مستوى الوصول والصلاحيات التي يحتاجها كل مستخدم بناءً على دوره ومسؤولياته.
- 3- تعبئة النماذج: ملء النماذج المطلوبة لإنشاء الحساب، والتي تتضمن هذه المعلومات المستخدم وبيانات الاتصال.
- الاسم.
- عنوان البريد الإلكتروني (إذا كان حساباً من نوع معين).
- كلمة المرور.
- تاريخ الميلاد (في بعض الحالات).
- معلومات إضافية أخرى (حسب نوع الحساب).
- 4- الموافقة: الحصول على موافقة من المسؤولين المعنيين قبل إنشاء الحساب.
- 5- إنشاء الحساب: إنشاء الحساب على النظام وتعيين كلمة مرور أولية.
- 6- تزويد المستخدم بالمعلومات: تزويد المستخدم بمعلومات تسجيل الدخول واسم المستخدم وكلمة المرور الأولية.
- إدارة الحسابات.

1.10.1.2 ما بعد إنشاء الحسابات:

- 1- تغيير كلمات المرور: إلزام المستخدمين بتغيير كلمات المرور بشكل دوري للحفاظ على الأمان.
- 2- تحديث المعلومات: تحديث معلومات المستخدمين بشكل دوري مثل بيانات الإتصال والمسمى الوظيفي.
- 3- تعديل الصلاحيات: تعديل صلاحيات المستخدمين حسب الحاجة، مثل إضافة أو إزالة الوصول إلى موارد معينة.
- 4- تعطيل الحسابات: تعطيل حسابات المستخدمين الذين يتكون العمل أو ينتقلون إلى إدارات أخرى.
- 5- مراقبة الحسابات: مراقبة نشاط المستخدمين على النظام للكشف عن أي أنشطة غير مصرح به.

1.10.1.3 ما بعد حذف الحسابات:

- 1- حذف الحسابات: حذف حسابات المستخدمين الذين يتكون العمل بشكل نهائي.
- 2- أرشفة البيانات: أرشفة بيانات المستخدمين المحذوفين للاحتفاظ بها لفترة محددة.
- 3- إلغاء الوصول: التأكد من إلغاء جميع أنواع الوصول إلى النظام بعد حذف الحساب.

1.10.2 اختبار الأنظمة:

يتم اختبار الأنظمة بشكل نصف سنوي من قبل مختبر اختراقات أنظمة خارجي للأنظمة الموجودة داخل الشركة، تغطي الجوانب التالية:

الرقم	اسم الاختبار	العملية
1	اختبار الاختراق (Penetration Testing)	محاكاة هجوم حقيقي على النظام لاختبار مدى قدرة النظام على صد الهجمات وذلك عن طريق محاولة الوصول غير المصرح به إلى النظام لتحديد الثغرات التي قد توجد.
2	اختبار الثغرات (Vulnerability Testing)	اكتشاف الثغرات الأمنية في النظام باستخدام أدوات برمجية متخصصة لتحديد نقاط الضعف في النظام التي قد يتسلل منها المهاجمون.
3	الاختبار على مستوى الشبكة (Network Testing)	فحص الشبكة لاكتشاف أي تهديدات أو ثغرات قد تؤثر على أمان الاتصال.
4	التصيد الاحتمالي (Phishing Testing)	محاكاة محاولات الهجوم التي تستهدف الموظفين أو المستخدمين للوصول إلى معلومات حساسة.
5	اختبار مقاومة الأنظمة ضد هجمات البرمجيات الخبيثة (Malware Testing)	اختبار الأنظمة للكشف عن قدرتها في التعامل مع البرمجيات الخبيثة مثل الفيروسات.
6	اختبار الأمان على مستوى الأجهزة (Hardware Security Testing)	اختبار الأجهزة مثل الخوادم، نقاط الوصول، أجهزة التوجيه، والمعدات الأخرى للكشف عن الثغرات في مكونات الأجهزة.
7	اختبار الاستجابة للحوادث (Incident Response Testing)	محاكاة هجوم سيبراني لمعرفة مدى جاهزية النظام للاستجابة بشكل صحيح وفعال. يشمل ذلك معرفة كيفية التعامل مع الحوادث وتوثيقها.

1.10.3 الاستجابة للحوادث:

يقصد بالحوادث انتهاك سياسة الاستخدام أو ممارسات الأمان التي تعرض سرية المعلومات والعمليات في خطر، مثل:

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

- محاولات الوصول غير المصرح به إلى المعلومات.

- الاستخدام غير المصرح به للمعلومات.

- التعديل غير المصرح به للمعلومات.

- فقدان المعلومات السرية والمحمية.

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

1.10.3.1 آلية الاستجابة للحوادث:

فيما يلي الخطوات المتبعة للتعامل مع الحوادث:

الرقم	اسم العملية	وصف العملية
1	التحضير	إنشاء فريق الاستجابة للحوادث وتحديد الخدمات والأدوات اللازمة
2	تحديد الحدث	تحديد نطاق التأثير ومدى الضرر الناجم عن الحادث وإبلاغ الأطراف المعنية
3	احتواء الحدث	الخطوات المتبعة لعدم انتشار نطاق الحادث لتقليل الأضرار الناجمة عنه وعزلها، مثل: إجراء نسخ احتياطي للنظام للحفاظ على الحالة الحالية للنظام وتغيير كلمات المرور للأنظمة المتأثرة.
4	الاستئصال	إزالة جميع مكونات وأعراض الحادث والتحقق من عدم تكرار الحادث، مثل: استخدام مجموعات أدوات إدارية منفصلة للتحقق من النظام، إعادة تثبيت نظام تشغيل جديد وتقوية نظام التشغيل (تطبيق التصحيحات، تعطيل الخدمات غير الضرورية، تثبيت برنامج مكافحة الفيروسات)
5	الاسترداد	الخطوات المطلوبة لاستعادة البيانات والأنظمة إلى حالة عملها الصحيحة للسماح بعودة العمليات الأساسية، مثل: استعادة بيانات النظام باستخدام نسخة احتياطية جديدة ووضع الأنظمة المتأثرة تحت المراقبة الشبكية لمحاولات غير مصرح بها في المستقبل
6	الدروس المستفادة	تحليل مابعد الحادث للأنظمة التي تأثرت والأنظمة الأخرى المعرضة للخطر وتقديم تقرير مفصل لها للإدارة.

إدارة الجودة والتطوير

Quality & Development Management

إدارة الجودة والتطوير

Quality & Development Management

1.11 تفويض الصلاحية:

تفويض الصلاحية يسعى لتحسين فعالية القرارات الإدارية عبر توضيح الحدود والمسؤوليات، مما يساهم في سلاسة العمليات، سوف يتم مراجعة مصفوفة تفويض الصلاحيات من قبل مشرف إدارة تقنية المعلومات وتعتمد من الرئيس التنفيذي سنوياً.

Quality & Development Management

Quality & Development Management

التعريفات والمصطلحات

الوصف	نوع الصلاحية	
الشخص الذي لديه مسؤولية نهائية وينفذ نشاطاً أو يقوم بالعمل (يقود مهمة أو نشاطاً معيناً).	مسؤول Responsible	R
مسؤول نهائي ومسؤول عن الموافقة وتقديم الضوء الأخضر النهائي بشأن المستند أو النشاط أو المهمة، بعد المراجعة والتأكيد على أن المستند أو النشاط أو المهمة قد تم إعدادها / إجرائها وفقاً لسياسات وعمليات وإجراءات المنظمة، واجتاز عملية المراجعة المطلوبة للمستند أو النشاط أو المهمة.	اعتماد Accountable/Approval	A
يأتي في اتصال ثنائي الاتجاه لغرض المراجعة والتوصية للموافقة، أو عرض اقتراح عام على عملية أو نشاط أو معاملة، وليس لديه سلطة اتخاذ القرار.	الاستشارة Consulted	C
الإشعار/الإبلاغ هو الطريقة الوحيدة للتواصل. هذا الشخص الذي يتم إبلاغه بنتيجة القرار دون الحاجة إلى اتخاذ قرار داخلي.	الإشعار Informed	I

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

تعريف المسميات الوظيفية

الرمز	المسمى الوظيفي
CEO	الرئيس التنفيذي Chief Executive Officer
LCM	مدير الشؤون القانونية والامتثال Legal and Compliance Manager
ITS	مشرف تقنية المعلومات Information Technology Manager
QDM	مدير إدارة الجودة والتطوير Quality and Development Manager



ملاحظات	QDM	LCM	ITS	CEO	بند الصلاحية
إدارة الجودة والتطوير	I	I	R	A	اعتماد سياسات قسم الأمن السيبراني
Quality & Development Management	C	I	A	I	اقتراح التعديل على السياسات
إدارة الجودة والتطوير	R	I	R	I	مراجعة التعديلات على السياسات
Quality & Development Management	I	I	R	A	اعتماد التعديلات على السياسات
إدارة الجودة والتطوير	I	I	R	A	اعتماد إجراءات قسم الأمن السيبراني
Quality & Development Management	C	I	A	I	اقتراح التعديلات على الإجراءات
إدارة الجودة والتطوير	R	I	R	I	مراجعة التعديلات على الإجراءات
Quality & Development Management	I	I	R	A	اعتماد التعديلات على الإجراءات

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

2 التقارير الداخلية

2.1 الخلفية:

يعمل مسؤول الأمن السيبراني على إعداد تقارير دورية تغطي الجوانب التالية

2.2 العملية:

الرقم	اسم التقرير	العملية	اجمالي الفترة الزمنية (بالأيام)	المسؤولية	إشارة المستند
1	تقرير مكافحة الفيروسات ESET	برنامج حماية يقوم باكتشاف وحظر وإزالة الفيروسات والبرامج الضارة.	يوميًا	مسؤول الأمن السيبراني	مشرف تقنية المعلومات
2	تقرير الحوادث الإلكترونية	تقرير يتضمن تفاصيل الهجمة أو الحادث الإلكتروني بما في ذلك وقت حدوثه وكيف حدث واثره ونطاق الاختراق.	يوميًا	مسؤول الأمن السيبراني	مشرف تقنية المعلومات
3	تقرير التقييم الذاتي	قياس مدى حوكمة الأمن السيبراني في الشركة.	كل 360 يوم	مسؤول الأمن السيبراني	إدارة الالتزام والامتثال



3 اللوائح السارية

يجب قراءة إجراءات التشغيل القياسية بالتماشي مع القوانين واللوائح والتعاميم الصادرة من هيئة التأمين والجهات المنظمة الأخرى والتي قد تشكل أو لا تشكل جزءاً من إجراءات التشغيل القياسية هذه والجدول التالي.

يجب أيضاً مراعاة التامة لأي قانون أو لائحة أو تعميم جديد أو محدث صادر من هيئة التأمين والجهات المنظمة الأخرى بعد تاريخ اعتماد إجراءات التشغيل القياسية هذه.

الرقم	اسم اللائحة/ التعميم	الجهة المنظمة	تاريخ الاصدار
1	لائحة وسطاء التأمين	هيئة التأمين	أكتوبر 2011
2	اللوائح التنفيذية لقانون مراقبة شركات التأمين التعاوني	هيئة التأمين	ابريل 2004
3	لائحة ادارة المخاطر	هيئة التأمين	ديسمبر 2008
4	لائحة مكافحة الاحتيال	هيئة التأمين	ديسمبر 2008
5	لائحة سلوكيات سوق التأمين	هيئة التأمين	اغسطس 2008
6	الدليل التنظيمي لأمن المعلومات	هيئة التأمين	مايو 2022
7	مبادئ تحليل التهديدات السيبرانية للقطاع المالي	هيئة التأمين	ابريل 2022
8	التأكيد على الإلتزام بالتعليمات الخاصة بحماية البيانات الشخصية للعملاء	البنك المركزي	جمادي الأول 1445
9	حماية البيانات الشخصية والسياسات والضوابط والقواعد الصادرة لحوكمة البيانات	البنك المركزي	جمادي الأول 1443

4 التوظيف والتدريب

تحدد ميزانية كل بداية سنة من الشركة يتم فيها رفع طلب لإدارة الموارد البشرية بعدد الموظفين المطلوبين في كل ربع من السنة حسب الميزانية المحددة والشواغل المتوفرة.

الإدارات الأخرى	قسم الأمن السيبراني	
1- يتم تدريب الإدارات الأخرى عن طريق توعيتهم بالهجمات السيبرانية وتحذيرهم عبر البريد الإلكتروني بالآتي: - استخدام كلمات مرور قوية: بحيث تكون طويلة ومعقدة وتجنب كلمات المرور سهلة التخمين. - تحديث البرامج بانتظام: بحيث يمنع استغلال الثغرات الأمنية التي يمكن أن يستغلها المهاجمون. - التحذير من رسائل البريد الإلكتروني المشبوهة: بحيث يتم فيها تجنب فتح رسائل البريد الإلكتروني والروابط المشبوهة التي قد تحتوي على برامج ضارة.	1- إدارة الموارد البشرية: إضافة الموظف الى نظام الموارد البشرية وتسليم العهدة له والتوقيع عليها. 2- إدارة تقنية المعلومات: - طلب وتجهيز الأجهزة اللازمة (مثل اللابتوبات، الشاشات، الهواتف) - إنشاء الحسابات الخاصة بالشركة (مثل البريد الإلكتروني، الرسائل الداخلية، أدوات الإنتاجية) - مساعدة الموظفين الجدد في إعداد أجهزتهم وحساباتهم - تقديم تدريب مبدئي عن كيفية استخدام أنظمة وأدوات الشركة - تقديم الدعم الفني المستمر والتدريب الإضافي عند الحاجة - التأكد من أن الموظفين الجدد يفهمون ويلتزمون بسياسات الأمن الخاصة بالأمن السيبراني	الموظف الجديد
-	1- الموارد البشرية: اشعار مشرف تقنية المعلومات بمغادرة الموظف أو تغيير دوره قبل اسبوعين على الأقل من تاريخ مغادرته. 2- إدارة تقنية المعلومات: يقوم مشرف الإدارة بالاجتماع مع الموظف ليتم فيه مناقشة آلية تسليم الأعمال المكلفة. بدوره يقوم الموظف بتسليم وثيقة مفصلة للمشرف توضح المشاريع والمهام والمسؤوليات الجارية المكلف بها. بعد اتمام جميع المهام والمشاريع المكلف بها يتم اتخاذ الإجراءات التالية في آخر يوم للموظف: 1- إدارة الموارد البشرية: حذف الموظف من نظام الموارد البشرية واستلام العهدة منه والتوقيع عليها. 2- إدارة تقنية المعلومات: تسليم الموظف بطاقة الموظف وحذفه من نظام البصمة وتعطيل صلاحياته في الوصول إلى جميع الأنظمة والتطبيقات. - تحديث قوائم الوصول ومجموعات الأمان لإزالة وصول الموظفين المغادرين. - جرد جميع أصول تقنية المعلومات المسترجعة ومسح البيانات على الأجهزة المسترجعة لضمان عدم ترك معلومات حساسة.	الموظف المغادر

5 حفظ السجلات

فيما يلي عملية حفظ السجلات:

5.1 السجلات الإلكترونية:

تتم أرشفة السجلات و أخذ نسخ احتياطي للبيانات بشكل منتظم حتى يتم استعادتها في حالة فقدانها أو تلفها. حيث تتم الأرشفة عن طريق جهاز (NAS (Network-attached storage وهو نظام تخزين مركزي يقوم بتخزين البيانات وعمل نسخ احتياطي لها عن طريق الإتصال بالشبكة بحيث يسمح للمتصلين بالشبكة من أجهزة متعددة بتخزين بياناتهم وأرشفتها.

الرقم	العملية	وصف العملية
1	إدارة الوصول إلى البيانات	يتم الوصول إلى البيانات من أي جهاز أو شبكة على الإنترنت
2	النسخ الاحتياطي	يدعم النسخ الاحتياطي التلقائي
3	الأمان	يمكن تشفير البيانات وتحديد الأذونات
4	التكلفة	تكلفة لمرة واحدة وتكاليف الصيانة
5	المرونة	يمكن إضافة محركات أقراص إضافية إلى جهاز NAS لزيادة سعة التخزين دون الحاجة لاستبدال الجهاز بالكامل.

5.1.1 استعادة المعلومات أو نقلها من جهاز لآخر:

يتم استعادة المعلومات الموجودة في الأجهزة ونقلها من جهاز لآخر عن طريق عملية النسخ الاحتياطي الموجودة في جهاز NAS.

5.1.2 خطة الطوارئ لتجنب فشل عملية النسخ الاحتياطي :

يوفر جهاز NAS آلية لحماية البيانات من خلال التخزين المكرر (RAID) وهي طريقة لتخزين نفس البيانات في أماكن مختلفة على أقراص صلبة متعددة أو محركات أقراص ذات حالة صلبة لحماية البيانات في حالة فشل محرك الأقراص لضمان عدم فقدان البيانات في حال حدوث مشاكل مع الأقراص الصلبة.

6 المراجع:

رقم	المراجع
1	استراتيجية الأمن السيبراني
2	سياسات وإجراءات الأمن السيبراني
3	أدوار ومسؤوليات الأمن السيبراني
4	منهجية إدارة مخاطر الأمن السيبراني
5	برنامج التوعية والتدريب على الأمن السيبراني
6	سياسة الأمن السيبراني في مشاريع تقنية المعلومات
7	سياسة الامتثال التنظيمي للأمن السيبراني
8	سياسة التقييم والتدقيق الدوري للأمن السيبراني
9	سياسة الأمن السيبراني في الموارد البشرية
10	سياسات ومعايير إدارة الأصول والاستخدام المقبول للأصول
11	سياسة ومعايير إدارة الهوية والوصول
12	سياسة حماية أنظمة المعلومات ومرافق المعالجة
13	سياسة ومعايير حماية البريد الإلكتروني
14	سياسة ومعايير إدارة أمن الشبكات
15	سياسة ومعايير أمن الخوادم
16	سياسة ومعايير إدارة التحديثات الأمنية
17	سياسة ومعايير أمن الأجهزة المحمولة
18	سياسة ومعايير حماية البيانات والمعلومات
19	سياسة ومعايير التشفير
20	سياسة ومعايير أمن قواعد البيانات
21	سياسة ومعايير إدارة النسخ الاحتياطي والاستعادة
22	سياسة ومعايير إدارة الثغرات الأمنية
23	سياسة ومعايير اختبار الاختراق



24	سياسة ومعيار إدارة سجلات الأحداث والمراقبة للأمن السيبراني
25	سياسة ومعيار إدارة الحوادث والتهديدات السيبرانية
26	سياسة ومعيار أمن مكافحة البرمجيات الضارة
27	سياسة ومعيار الأمن المادي
28	سياسة ومعيار أمن تطبيقات الويب
29	سياسة إدارة استمرارية الأعمال في الجوانب المتعلقة بالمرونة السيبرانية
30	سياسة الأمن السيبراني لمقدمي الخدمات الخارجيين
31	سياسة الأمن السيبراني للحوسبة السحابية والاستضافة

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

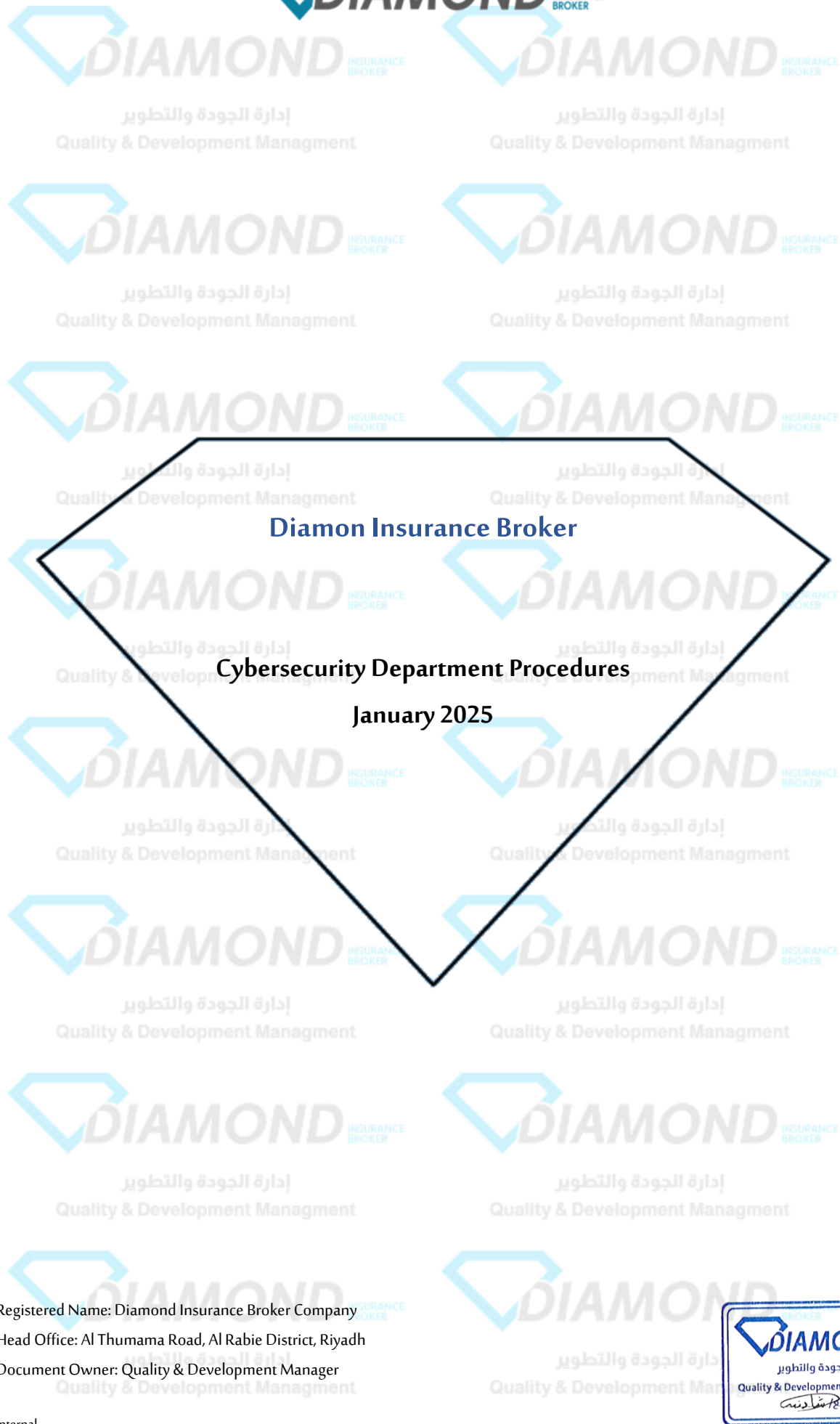
إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management

إدارة الجودة والتطوير
Quality & Development Management



Diamond Insurance Broker

Cybersecurity Department Procedures

January 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY



Document Management

Document Control:

Signature	Date	Job Title	Prepared By
	26/01/2025	Quality And Development Specialist	Nouf Alraouji
Signature	Date	Job Title	Reviewed By
	02/02/2025	Quality And Development Manager	Shaden Alotaibi
Signature	Date	Job Title	Initial Approval
	13/03/2025	Information Technology Supervisor	Jithin Varkey
Signature	Date	Job Title	Final Approval
	13/03/2025	Chief Executive Officer	Bader Alshaya

Review Date: إدارة الجودة والتطوير

Description of Change	Section Affected	Effective Date	Issue Number
إدارة الجودة والتطوير Quality & Development Managment		إدارة الجودة والتطوير Quality & Development Managment	

Article (1): This document and the information it contains are related to Al Wathiqah Al Massiya Insurance Broker (Diamond). They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.



Table of Contents

Document Management

Section 1 – Standard Operating Procedures

.1	Introduction	
1.1	Objectives	
1.2	Target Audience	
1.3	Definitions	
1.4	Document Control	
1.5	Ownership and Review	
1.6	Changes to the Standard Operating Procedures	
1.7	IT Applications	
1.8	Key Activities	
1.9	Department Overview	
1.10	Roles and Responsibilities	
1.10.1	Identity and Access Management	
1.10.1.1	Account Creation	
1.10.1.2	Post-Account Creation Activities	
1.10.1.3	Post-Account Deletion Activities	
1.10.2	System Testing	
1.10.3	Incident Response	
1.10.3.1	Incident Response Mechanism	
1.11	Authority Delegation	
.2	Internal Reports	
2.1	Background	
2.2	Process	
.3	Applicable Regulations	
.4	Recruitment and Training	
.5	Records Retention	
5.1	Electronic Records	
5.1.1	Retrieval or Transfer of Information Between Devices	
5.1.2	Emergency Plan to Avoid Backup Failure	
6	References	

Section 1 – Standard Operating Procedures

1. Introduction:

Diamond Al-Watheqa Insurance Brokerage Company (hereinafter referred to as “Diamond”) believes that the purpose of its Standard Operating Procedures (SOPs) is to enable the organization to achieve its strategic objectives through robust security practices. These practices allow the company to protect its data and digital assets, ensuring business continuity and maintaining its reputation.

The SOPs define the roles, responsibilities, and processes for individuals involved in cybersecurity support activities. They also establish key controls within the activities carried out by the Cybersecurity Department to strengthen the overall structure of the company.

1.1 Objectives:

The objectives of these Standard Operating Procedures (SOPs) are to:

- Protect information assets, including data, systems, and applications, from cyber threats.
- Ensure business continuity by safeguarding computer systems and networks from theft, damage, or unauthorized access to retained data.
- Maintain the company’s reputation by protecting the confidentiality of client information, which in turn strengthens customer trust in the company.

1.2 Target Audience:

The following groups are the intended audience for this document:

- The Cybersecurity Department
- Employees within the Cybersecurity Department

1.3 Definitions:

Below are key abbreviations and definitions relevant to these procedures:

1.3.1 Cybersecurity Terms :

- **Malware:** Malicious software designed to damage or disrupt computer systems. Examples include viruses, worms, ransomware, and spyware.
- **Cyberattack:** An attempt to exploit vulnerabilities in a system or network to gain unauthorized access to data or to disrupt services.
- **Phishing:** A type of cyberattack that attempts to trick users into revealing sensitive information such as passwords or credit card numbers, often by impersonating a trusted entity in electronic communications.
- **Denial of Service (DoS/DDoS):** An attempt to make a service or website unavailable by overwhelming it with a large amount of traffic.
- **Man-in-the-Middle Attack:** Intercepting communication between two parties to steal or alter transmitted data.
- **Hacking:** Attempting to gain unauthorized access to a system or network.
- **Vulnerabilities:** Weaknesses in a computer system, application, or network that can be exploited by attackers to gain unauthorized access to data or systems.

1.3.2 Cybersecurity Concepts :

- **Cybersecurity:** A set of measures and technologies used to protect electronic systems, networks, and data from cyber threats.
- **Firewall:** A network security system that monitors and controls incoming and outgoing network traffic based on predefined security rules.
- **Encryption:** The process of converting data into an unreadable format to protect it from unauthorized access.
- **Authentication:** The process of verifying the identity of a user or device.
- **Authorization:** The process of granting permissions or access rights to a user or device.
- **Backup:** The creation of a copy of data to restore it in case of loss or damage.
- **Business Continuity:** Plans and procedures designed to ensure the continuation of business operations in the event of a disaster or cyberattack.
- **Disaster Recovery:** Plans and procedures aimed at restoring systems and data following a disaster.

1.3.3 Administrative Terms:

- CEO: Chief Executive Officer
- HRM :Human Resources Manager
- ITM :Information Technology Manager
- TM :Technical Manager
- FM :Finance Manager
- LCM :Legal and Compliance manager
- OM :Operation Manager
- SMD :Sales and Marketing Director
- QDM :Quality and Development Manager

1.4 Document Control:

- The contents of this Standard Operating Procedures (SOP) document are confidential and intended for internal use only within the company. It must always be stored securely and must not be copied or disclosed to third parties.
- This document, in whole or in part, may only be distributed as authorized by the Quality and Development Manager.
- Relevant sections of the SOP must be reviewed and understood by concerned employees to ensure adherence to the Cybersecurity Department's procedures.
- A hard copy of this document shall be retained by the Quality and Development Department.

1.5 Ownership and Review:

While this document serves as guidance and direction for managing the operations of the Cybersecurity Department, it is important to note:

- The Managing Director provides final approval of the Standard Operating Procedures.
- The Board of Directors oversees SOP governance and ensure they are formally approved and reviewed annually.
- The document is managed under the direct supervision of the IT Supervisor.
- The Quality and Development Department, in coordination with the Compliance Department, ensures that the implemented controls are appropriate and sufficient in accordance with cybersecurity procedures.

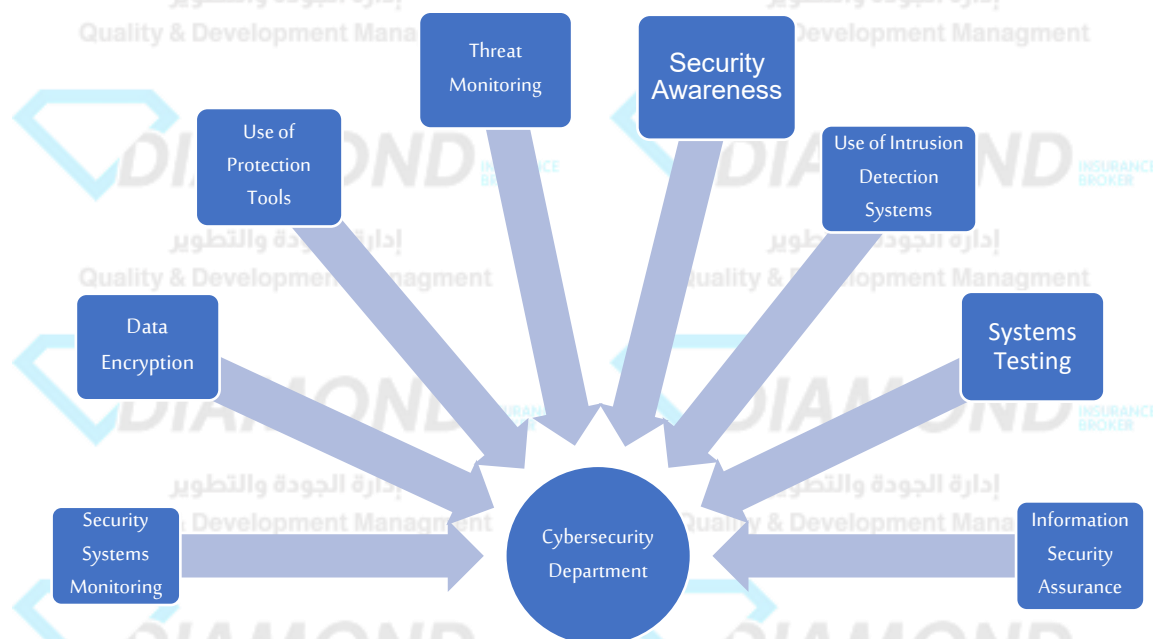
1.6 Changes to the Standard Operating Procedures:

Modifications to this Standard Operating Procedure (SOP) are made annually as needed. However, under exceptional circumstances, including but not limited to the situations described below, changes may be implemented upon request. Changes to the document are typically of the following nature:

- Changes in laws and regulations.
- Changes in the company's functions and activities.
- Changes in work procedures.
- Changes in Diamond's organizational structure.
- Changes in roles, duties, and job descriptions.
- Changes in the risk landscape in which the company operates.
- Any other changes in regulations, strategy, or operations.

1.7 IT Applications:

Intrusion Detection Systems (IDS) are used to detect cyberattacks. Additionally, various protection tools, security installations, and antivirus software are employed to safeguard the company's digital environment.



1.8 Key Activities:

This section clearly defines the steps and tasks within the Cybersecurity Department to ensure smooth and efficient operations by providing cybersecurity support to all departments across the company.

1.9 Department Overview:

The following diagram illustrates the current organizational structure of the Cybersecurity Department:



1.10 Roles and Responsibilities:

Responsibility	Activity	Subprocess
Cybersecurity Officer	The company adopts an integrated cybersecurity strategy that includes: -Conducting periodic security risk assessments. -Utilizing firewalls and advanced threat detection systems. -Applying encryption techniques to protect data during transmission and storage.	Risk Management
Cybersecurity Officer	Compliance with the National Cybersecurity Authority (NCA) and the Insurance Authority (AI) regulations: -Implementing the AI Cybersecurity Framework standards to ensure full compliance within the insurance sector. -Adopting global best practices such as ISO 27001 and the NIST Cybersecurity Framework. -Executing a periodic cybersecurity risk assessment program to identify vulnerabilities and mitigate risks Third-Party Risk Management (TPRM): -Establishing strict security requirements for technology service providers, including cloud systems and managed service providers. -Conducting annual data security audits for suppliers to ensure compliance with company policies.	Regulatory Compliance and Cybersecurity Governance
Cybersecurity Officer	-Complying with AI requirements for reporting cybersecurity incidents within specified timeframes.	Security Reporting and Compliance



Responsibility	Activity	Subprocess
	-Maintaining electronic incident records for auditing and regulatory compliance.	
Cybersecurity Officer	-Utilizing necessary tools to manage passwords and define access privileges. -Defining access levels based on job roles to ensure unauthorized users cannot access sensitive information.	Access Control and Authority Matrix
Cybersecurity Officer	The company is committed to enforcing strict policies to protect customer data in accordance with applicable regulations such as the General Data Protection Regulation (GDPR) and the Saudi Personal Data Protection Law (PDPL), which include: -Defining mechanisms for storing and securing sensitive data. -Controlling access to data based on roles and permissions. -Establishing procedures to monitor usage and prevent data leaks.	Data Protection and Privacy
Cybersecurity Officer	-Using AI-driven Security Information and Event Management (SIEM) systems to monitor the network and detect any unusual activities. -Implementing Security Orchestration, Automation, and Response (SOAR) systems to immediately combat attacks.	Cyber Threat Protection Using Artificial Intelligence (AI) and Security Analytics
Cybersecurity Officer	-Monitoring potential leaks of company or customer data on the dark web. -Subscribing to cyber threat intelligence databases to keep cybersecurity defenses up to date.	Dark Web Monitoring
Cybersecurity Officer	-Applying advanced endpoint protection systems (EDR/XDR) to prevent malware	Advanced Endpoint and Server Protection

Responsibility	Activity	Subprocess
	and advanced persistent threat (APT) attacks. -Deploying Next-Generation Firewalls (NGFW) to monitor suspicious activities and prevent intrusions.	
Cybersecurity Officer	- Monitoring user behavior on the network using User Behavior Analytics (UBA). - Enforcing strict policies for accessing sensitive data and preventing its transfer outside the company.	Insider Threat Protection
Cybersecurity Officer	It involves continuous monitoring of systems and networks to detect any suspicious activity.	Systems and Network Monitoring
Cybersecurity Officer	It assists in identifying vulnerabilities within the company's systems and in assessing potential risks.	Risk Identification
Cybersecurity Officer	Protection of data from breaches and viruses by utilizing antivirus software.	Information Security Assurance
Cybersecurity Officer	- Raising employee awareness about cybersecurity risks and educating them on best security practices. -Organizing monthly phishing simulation tests to assess employees' ability to detect fraudulent attempts. -Sending periodic alerts via email about the latest cybersecurity threats.	Security Awareness
Cybersecurity Officer	Computer data is regularly backed up and archived to enable recovery in case of data loss or tampering.	Data Backup
Cybersecurity Officer	- Regularly backing up data and restoring it when necessary.	Business Continuity and Disaster Recovery Plan

Responsibility	Activity	Subprocess
	-Maintaining an incident response plan for cyberattacks, including ransomware attacks. -Establishing clear mechanisms for crisis and emergency management.	
Cybersecurity Officer	-Conducting simulations of sophisticated cyberattacks such as Advanced Persistent Threats (APT). -Assessing the cybersecurity team's readiness to respond to security breaches.	Periodic Offensive Security Testing (Red Team vs. Blue Team Drills)
Cybersecurity Officer	Developing a Cyber Resilience Strategy: Implementing a Ransomware Response Plan to rapidly restore data. Enforcing Immutable Backup Storage to protect backup data from alteration.	Enhanced Incident Response and Business Continuity Planning
Cybersecurity Officer	Applying the Zero Trust Architecture (ZTA) Approach: -Enforcing continuous authentication policies for every access attempt, including those originating from within the internal network. -Enforcing Least Privilege Access Control (LPAC) policies.	Advanced Cybersecurity Technologies
Cybersecurity Officer	Securing Cloud Environments: -Implementing Cloud Security Policies in accordance with Cloud Security Posture Management (CSPM) standards. -Enforcing encryption of cloud storage data using AES-256 protocols.	Cybersecurity in Cloud Infrastructure

1.10.1 Identity and Access Management:

Refers to managing user identities and controlling access to systems and data according to appropriate permissions only.

1.10.1.1 Account Creation :

- 1 - **User Identification:** Identify employees or users who require system accounts.
- 2- **Permission Assignment:** Define the level of access and permissions each user needs based on their role and responsibilities.
- 3- **Form Completion:** Fill out the necessary forms for account creation, which include the following user and contact information:
 - Name
 - Email address (if applicable for the account type)
 - Password
 - Date of birth (in some cases)
 - Additional information (depending on the account type)
 - Approval: Obtain approval from the relevant authorities before creating the account.
- 4- **Account Creation:** Create the account in the system and assign an initial password.
- 5- **User Notification:** Provide the user with login information, including username and initial password.

1.10.1.2 Post-Account Creation :

- 1- **Password Changes:** Require users to change passwords periodically to maintain security.
- 2- **Information Updates:** Regularly update user information such as contact details and job titles.
- 3- **Permission Modifications:** Adjust user permissions as needed, such as adding or removing access to specific resources.
- 4- **Account Deactivation:** Disable accounts for users who leave the company or transfer to other departments.
- 5- **Account Monitoring:** Monitor user activity on the system to detect any unauthorized actions.

1.10.1.3 Post Account Deletion :

- 1- **Account Deletion:** Permanently delete accounts of users who have left the company.
- 2- **Data Archiving:** Archive deleted users' data for a defined retention period.
- 3- **Access Revocation:** Ensure all types of system access are revoked after account deletion.

1.10.2 System Testing:

System testing is conducted biannually by an external penetration testing provider for the systems within the company. These tests cover the following aspects:

No.	Test Name	Description
1	Penetration Testing	Simulates a real-world attack on the system to assess its ability to resist unauthorized access attempts and identify potential vulnerabilities.
2	Vulnerability Testing	Utilizes specialized software tools to scan and identify security weaknesses in the system that could be exploited by attackers.
3	Network Testing	Examines the network infrastructure to detect threats or vulnerabilities that could compromise the security of communications and data flow.
4	Phishing Testing	Simulates phishing attacks targeting employees or users to assess their awareness and determine the organization's exposure to social engineering threats.
5	Malware Testing	Evaluates the system's ability to detect and respond to malicious software such as viruses, ransomware, and trojans.
6	Hardware Security Testing	Assesses hardware components such as servers, access points, routers, and other equipment for potential physical or firmware-level vulnerabilities.
7	Incident Response Testing	Simulates a cyberattack scenario to test the organization's readiness to effectively respond to and document security incidents.

1.10.3 Incident Response:

An incident is defined as a violation of usage policies or security practices that compromises the confidentiality, integrity, or availability of information or operations, such as:

- Unauthorized attempts to access information.
- Unauthorized use of data.
- Unauthorized modification of data.
- Loss of confidential and protected information.

1.10.3.1 Incident Response Mechanism:

The following table outlines the standard steps followed when responding to a cybersecurity incident :

No.	Process Name	Description
1	Preparation	Establishing the Incident Response Team (IRT) and identifying the necessary tools and services required for effective incident handling.
2	Incident Identification	Determining the scope and impact of the incident and notifying the relevant stakeholders.
3	Containment	Actions taken to prevent the spread of the incident and minimize its impact, such as:
4	Eradication	Removing all components and symptoms of the incident and verifying that it does not recur such as using separate administrative toolsets to inspect the system reinstalling a new operating system and hardening it by applying patches disabling unnecessary services and installing antivirus software
5	Recovery	The necessary steps to restore data and systems to their proper working condition to allow the resumption of core operations such as restoring system data using a new backup and placing the affected systems under network monitoring for unauthorized attempts in the future
6	Lessons Learned	Analysis after the incident of the affected systems and other systems at risk and providing a detailed report to management

1.11 Delegation of Authority:

Delegation of authority aims to enhance the effectiveness of administrative decisions by clarifying boundaries and responsibilities, thereby contributing to smoother operations. The Delegation of Authority Matrix will be reviewed annually by the IT Management Supervisor and approved by the Chief Executive Officer.

■ Definitions and Terminology

Permission Type		Description
R	Responsible	The person who has the ultimate responsibility and performs the activity or carries out the task (leads a specific task or activity).
A	Accountable / Approval	The final responsible person who approves and gives the final green light on a document, activity, or task after reviewing and ensuring it has been prepared/executed according to the organization's policies, processes, and procedures, and has passed the required review process.
C	Consulted	Engages in two-way communication for review and recommendation for approval, or provides general suggestions on a process, activity, or transaction, without decision-making authority.
I	Informed	Notification or reporting is the only method of communication. This person is informed of the outcome of the decision without needing to make an internal decision.

● Job Title Definitions

Code	Job Title
CEO	Chief Executive Officer
ITS	Information Technology Supervisor
LCM	Legal and Compliance Manager
QDM	Quality and Development Manager

Authorization Item	CEO	ITS	LCM	QDM	Notes
Approval of IT Management Policies	A	R	I	I	
Proposal of Policy Amendments	I	A	I	C	
Review of Policy Amendments	I	R	I	R	
Approval of Policy Amendments	A	R	I	I	
Approval of IT Management Procedures	A	R	I	I	
Proposal of Procedure Amendments	I	A	I	C	
Review of Procedure Amendments	I	R	I	R	
Approval of Procedure Amendments	A	R	I	I	

2 Internal Reports

1.2 Background:

the Cybersecurity Officer is responsible for preparing periodic reports covering the following aspects:

1.2 Process:

3 Applicable Regulations:

The Standard Operating Procedures (SOPs) must be read in conjunction with the laws, regulations, and circulars issued by the Insurance Authority and other regulatory bodies, which may or may not form part of these SOPs and the following table.

Full consideration must also be given to any new or updated law, regulation, or circular issued by the Insurance Authority or other regulatory bodies after the approval date of these Standard Operating Procedures.

No.	Regulation / Circular Name	Regulatory Authority	Date of Issue
1	Insurance Brokers Regulation	Insurance Authority	October 2011
2	Implementing Regulations of the Cooperative Insurance Companies Control Law	Insurance Authority	April 2004
3	Risk Management Regulation	Insurance Authority	December 2008
4	Anti-Fraud Regulation	Insurance Authority	December 2008
5	Insurance Market Conduct Regulation	Insurance Authority	August 2008

4 Recruitment and Training:

At the beginning of each year, a budget is determined by the company. A request is then submitted to the Human Resources Department specifying the number of required employees for each quarter of the year, based on the approved budget and available vacancies.

Other Management	Information Technology Management	
-1 Other departments are trained on the use of systems such as the Customer Relationship Management (CRM) system and the Human Resources Management System (HRMS) twice a year.	1 -Human Resources Department: -Add the new employee to the HR system. -Hand over company assets (equipment, etc.) to the employee and obtain their signature. 2 . IT Department: - Request and prepare the necessary equipment (e.g., laptops, monitors, phones). -Create company accounts (such as email, internal messaging, productivity tools). -Assist new employees in setting up their devices and accounts. -Provide initial training on how to use company systems and tools. -Offer ongoing technical support and additional training as needed. -Ensure new employees understand and comply with IT security policies.	New Employee
	Human Resources Department: Notify the IT supervisor of the employee's departure or role change at least two weeks before the employee's last day. 2. IT Department: The IT manager meets with the departing employee to discuss the handover of assigned tasks. The employee submits a detailed document to the manager outlining ongoing projects, tasks, and responsibilities. After completing all assigned tasks and projects, the following steps are taken on the employee's last day: 1. Human Resources Department: - Remove the employee from the HR system. - Collect company assets from the employee and obtain their signature. 2. IT Department: - Collect the employee's ID card.	Departing Employee



	Remove the employee from the attendance system and disable their access to all systems and applications. Update access lists and security groups to revoke permissions for departing employees. Inventory all returned IT assets and securely erase data from -recovered devices to ensure no sensitive information remains	
--	--	--

5 Records Management:

The following outlines the records retention process:

5.1 Electronic Records:

Records are archived and backed up using a NAS (Network-Attached Storage) device. This centralized storage system connects to the network, allowing multiple devices within the network to store and archive their data. The NAS ensures secure data backup and facilitates efficient data management and retrieval across the organization.

No.	Process	Process Description
1	Data Access	Data can be accessed from any device or network via the internet.
2	Backup	Supports automatic backup.
3	Security	Data can be encrypted, and permissions can be set.
4	Cost	One-time cost-plus maintenance costs.
5	Flexibility	Additional drives can be added to the NAS device to increase storage capacity without replacing the entire unit.

5.1.1 Data Information Transfer or Retrieval Between Devices:

Information stored on devices can be recovered or transferred from one device to another using the backup process provided by the NAS device.

5.1.2 Backup Failure Emergency Plan:

The NAS device provides a data protection mechanism called RAID (Redundant Array of Independent Disks), which stores identical copies of data across multiple hard drives or solid-state drives. This setup ensures that if one drive fails, data is not lost and can be recovered, thereby safeguarding against backup failures caused by hardware issues.

6 References:

No.	Reference
1	Cybersecurity Strategy
2	Cybersecurity Policies and Procedures
3	Cybersecurity Roles and Responsibilities
4	Cybersecurity Risk Management Methodology
5	Cybersecurity Awareness and Training Program
6	Cybersecurity Policy for IT Projects
7	Cybersecurity Regulatory Compliance Policy
8	Cybersecurity Assessment and Audit Policy
9	Cybersecurity Policy for Human Resources
10	Asset Management and Acceptable Use Policies and Standards
11	Identity and Access Management Policy and Standard
12	Information Systems and Processing Facilities Protection Policy
13	Email Security Policy and Standard
14	Network Security Management Policy and Standard
15	Server Security Policy and Standard
16	Security Patch Management Policy and Standard
17	Mobile Device Security Policy and Standard

18	Data and Information Protection Policy and Standard
19	Encryption Policy and Standard
20	Database Security Policy and Standard
21	Backup and Recovery Management Policy and Standard
22	Vulnerability Management Policy and Standard
23	Penetration Testing Policy and Standard
24	Cybersecurity Event Logging and Monitoring Policy and Standard
25	Cybersecurity Incident and Threat Management Policy and Standard
26	Malware Protection Policy and Standard
27	Physical Security Policy and Standard
28	Web Application Security Policy and Standard
29	Business Continuity Policy (Cyber Resilience Focus)
30	Cybersecurity Policy for Third-Party Service Providers
31	Cybersecurity Policy for Cloud Computing and Hosting